

BuildWeek_III_Linux_server

Consegna

Obiettivi

In questo laboratorio, userai la riga di comando Linux per identificare i server in esecuzione su un dato computer.

- Parte 1 Server
- Parte 2 Usare Telnet per Testare i Servizi TCP

Attrezzatura Raccomandata

- Macchina virtuale CyberOps Workstation

Istruzioni

Parte 1 Server

I server sono essenzialmente programmi scritti per fornire informazioni specifiche su richiesta. I client, che sono anch'essi programmi, contattano il server, inoltrano la richiesta e attendono la risposta del server.

Possono essere utilizzate molte diverse tecnologie di comunicazione client-server, la più comune delle quali sono le reti IP. Questo laboratorio si concentra su server e client basati su rete IP.

Parte 2 Telnet

Telnet è una semplice applicazione di shell remota. Telnet è considerato insicuro perché non fornisce crittografia. Gli amministratori che scelgono di usare Telnet per gestire remotamente dispositivi di rete e server esporranno le credenziali di accesso a quel server, poiché Telnet trasmetterà i dati della sessione in chiaro.

Sebbene Telnet non sia raccomandato come applicazione di shell remota, può essere molto utile per testare rapidamente o raccogliere informazioni sui servizi TCP. Il protocollo Telnet opera sulla porta 23 usando TCP per impostazione predefinita. Il client telnet, tuttavia, permette di specificare una porta diversa. Cambiando la porta e connettendosi a un server, il client telnet permette a un analista di rete di valutare rapidamente la natura di un server specifico comunicando direttamente con esso.

Svolgimento

Parte 1

Perché è stato necessario eseguire `ps` come root (premettendo il comando con `sudo`)?

Si è usato `sudo ps` perché per vedere **tutte** le informazioni sui processi del sistema (in particolare quelli di altri utenti o del kernel) sono necessari privilegi elevati: senza `root` molte informazioni in `/proc` vengono nascoste per motivi di sicurezza o per configurazioni del sistema.

Come viene rappresentata la gerarchia dei processi da `ps`?

La gerarchia dei processi in Linux è la relazione padre-figlio tra processi: ogni processo ha un PID (process identifier) e un PPID (parent PID). Il comando mostra questa struttura come un *albero* (tree/forest), visualizzando graficamente quali processi hanno avviato quali figli indentandoli sotto ad essi.

Qual è il significato delle opzioni `-t`, `-u`, `-n`, `-a` e `-p` in `netstat`? (uso `man netstat` per rispondere)

`-t` — mostra SOLO le connessioni TCP.

```
[ --tcp|-t ]
```

`-u` — mostra SOLO le connessioni UDP.

```
[ --udp|-u ]
```

`-n` — visualizza indirizzi e porte in forma numerica (no name resolution).

```
--numeric, -n
    Show numerical addresses instead of trying to determine symbolic host, port or user names.
```

`-a` — mostra **tutte** le socket (listening e non-listening).

```
-a, --all
    Show both listening and non-listening sockets. With the --interfaces option, show interfaces that are not up
```

`-p` — mostra PID e nome del programma proprietario della socket.

-p, --program

Show the PID and name of the program to which each socket belongs.

L'ordine delle opzioni è importante per netstat?

No, nella pratica comune l'ordine delle opzioni non è significativo; è possibile combinarle in qualsiasi ordine o raggrupparle. L'unica attenzione è per le opzioni che richiedono un argomento in quel caso l'argomento deve seguire l'opzione come previsto dal man.

Basandosi sull'output di netstat mostrato al punto (d), qual è il protocollo di Livello 4, lo stato della connessione e il PID del processo in esecuzione sulla porta 80?

- Protocollo di Livello 4: TCP
- Stato della connessione: LISTEN
- PID del processo: 1007/nginx: master

Sebbene i numeri di porta siano solo una convenzione, puoi indovinare che tipo di servizio è in esecuzione sulla porta 80 TCP?

Di solito la porta 80 è la standard per il server web (http) ed anche in questo caso, NGINX è il servizio attivo ed è un Web Server.

```
[analyst@secOps ~]$ sudo ps -elf | grep 395
[sudo] password for analyst:
 1 S root      395      1  0  80  0 -  1829   19:33 ?        00:00:00 nginx: master process /usr/bin/nginx
 5 S http      396    395  0  80  0 -  1866   19:33 ?        00:00:00 nginx: worker process
 0 S analyst  3789  1872  0  80  0 -  1190   19:53 pts/0    00:00:00 grep 395
```

Il processo PID 395 è nginx. Come si potrebbe concludere questo dall'output sopra?

Osservando la prima riga possiamo concludere che il PID 395 è nginx perché viene indicato come processo master.

Cos'è nginx? Qual è la sua funzione? (Usa google per saperne di più su nginx)

Nginx è un Server Web open source ad alte prestazioni noto per la sua architettura asincrona basata su eventi, che gli permette di gestire un numero elevato di connessioni simultanee con un utilizzo minimo di memoria.

Funzioni di NGINX:

- Server Web Statico: Serve file statici come HTML, CSS, immagini e JavaScript con grande velocità ed efficienza.
- Reverse Proxy: Agisce da intermediario tra i client e i server applicativi di backend, inoltrando le richieste.
- Load Balancer (Bilanciatore di Carico): Distribuisce il traffico in entrata su più server per prevenire il sovraccarico e garantire alta disponibilità e scalabilità.
- Cache HTTP: Memorizza i contenuti richiesti di frequente per ridurre i tempi di risposta e alleggerire il carico sui server di backend.

La seconda riga mostra che il processo 396 è di proprietà di un utente chiamato http e ha il processo numero 395 come processo genitore. Cosa significa? È un comportamento comune?

Il processo worker viene fatto partire con l'utente http per sicurezza, con privilegi limitati per leggere i file del sito web e scrivere nei file di log; non può accedere a file di sistema critici, modificare configurazioni di altri utenti o prendere il controllo del sistema, garantendo che il processo master e il sistema operativo rimangano protetti in caso di attacco.

Perché l'ultima riga mostra `grep 395`?

Perché viene utilizzato per filtrare l'output e mostrare solo il processo interessato..

`ps -elf | grep 395`:

- Il comando `ps -elf` elenca tutti i processi attivi.
- La pipe (`|`) invia questo elenco al comando `grep`.
- Il comando `grep 395` cerca le righe contenenti la stringa "395"

Parte 2

Perché l'errore è stato inviato come pagina web?

Perché nginx è un **server HTTP**: quando riceve dati su una socket TCP li interpreta secondo il protocollo HTTP; se i dati non rispettano il formato atteso risponde con una **risposta HTTP** (tipicamente uno status di errore) il cui corpo è una pagina HTML impostata come pagina di errore dal server.

Usa Telnet per connetterti alla porta 68. Cosa succede? Spiega.

Tentando di collegarsi con Telnet alla porta 68 su localhost, la connessione è stata rifiutata con il messaggio "Unable to connect to remote host: Connection refused". Questo accade perché la porta 68 non è usata da un servizio TCP in ascolto: è riservata al protocollo DHCP client, che funziona su UDP, non su TCP.

Telnet invece tenta una connessione TCP, quindi non trova alcun processo che accetti la connessione e riceve un rifiuto.

```
[analyst@secOps ~]$ telnet 127.0.0.1 68
Trying 127.0.0.1...
telnet: Unable to connect to remote host: Connection refused
```

Domande di Riflessione

1. Quali sono i vantaggi dell'uso di netstat?

netstat permette di ottenere rapidamente una fotografia delle socket di rete locali: quali porte sono in ascolto, quali connessioni sono attive, gli stati TCP (ESTABLISHED, LISTEN, ...), le tabelle di routing e, con **-p**, il processo proprietario della socket.

Questo lo rende utile per troubleshooting (trovare quale servizio occupa una porta), audit base (verificare servizi esposti), monitoraggio rapido e raccolta di evidenze per incident response.

2. Quali sono i vantaggi dell'uso di Telnet? È sicuro?

telnet è un client TCP "raw" molto utile per test rapidi: permette di aprire una connessione a qualsiasi porta TCP e inviare dati manuali, utile per banner grabbing, verificare se una porta risponde, testare protocolli line-oriented (es. SMTP, HTTP basic, POP3) o simulare richieste al volo. Pro: semplicità, immediata interazione byte-stream, utile in laboratorio e troubleshooting.

Contro/sicurezza: **Telnet non è sicuro** per l'uso come shell remota perché trasmette tutto in chiaro (credenziali incluse). Per accesso remoto sicuro si usa SSH; per testare servizi cifrati o inviare pacchetti UDP si usano strumenti più appropriati (**openssl s_client, nc -u, socat, tcpdump**).